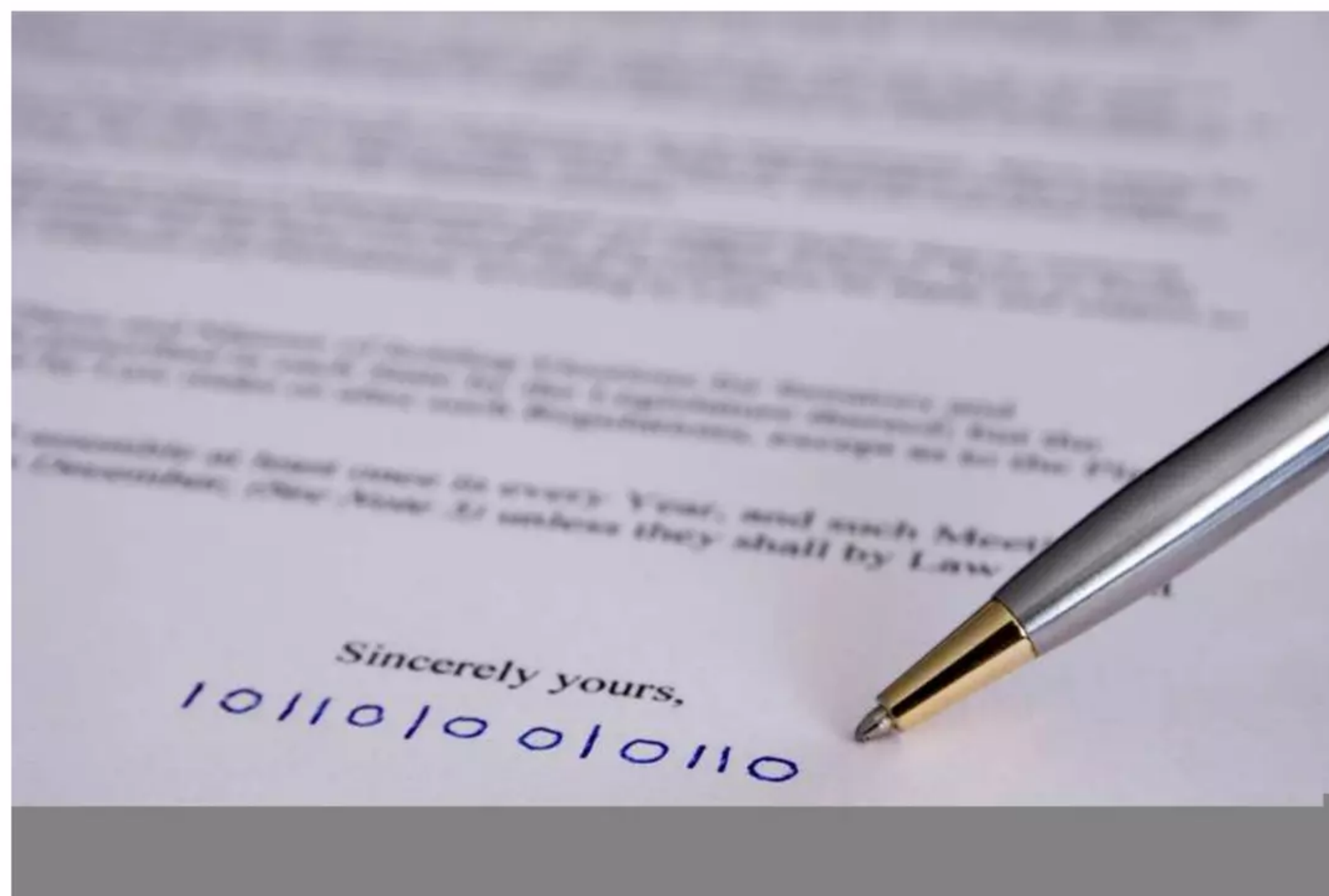


L'impiego delle tecnologie di firma digitale per la tutela della confidenzialità

Sikurezza.org - Infosecurity 2006



\$ whois naif

Fabio Pietrosanti (non pietro-santi!)

Privacy Architect @ www.khamsa.ch

Analisi, Progettazione e implementazione di soluzioni e architetture di tutela della riservatezza delle informazioni.

Diffusione delle informazioni e cultura sulla sicurezza: Sikurezza.org!

This page intentionally left
blank

\$ whois sikurezza.org



Sikurezza.org è una comunità virtuale di persone che per passione e/o lavoro si interessano di problematiche di (in)sicurezza informatica e della loro diffusione.

Si tratta di un progetto non commerciale portato avanti da volontari.



This page is unintentionally
left blank

Finalità

Comprendere i vantaggi e i limiti
delle tecnologie di firma
digitale per la tutela della
riservatezza delle comunicazioni

Prerequisiti

Concetti base di firma digitale
Bisogno di tutela delle
informazioni

Visione delle informazioni per quel
che queste sono

Requisiti di un sistema sicuro

Confidenzialità

Integrità

Disponibilità

Firma digitale: usi e limiti

Firma digitale: è importante

Risolve in modo decisivo il problema della gestione delle identità nella società dell'informazione

Bisogno di un meccanismo di identificazione non ripudiabile

La firma digitale è ovunque

Firma digitale per archiviazione
sostitutiva

Firma digitale per la PEC

Firma digitale per carte di
identificazione e carte di
servizi

Firma digitale per le SIM GSM

Firma digitale per i server web

Firma digitale: limiti d'uso (1)

Viene usata esclusivamente per la gestione delle identità

È poco usata nei client con chiavi software

Le interfacce smartcard non sono di default nei computer

I supporti software per smartcard sono ancora poco interoperabili

Firma digitale: limiti d'uso (2)

Non prevede meccanismi efficienti di gestione della mobilità (Autorilascio di certificati temporanei)

Non con tutti i certificati si può fare tutto (Bit di usage)

Non è mai stato standardizzato un meccanismo di interoperabilità con altri sistemi PKI (OpenPGP)

Firma digitale e riservatezza

Perché sono usate altre tecnologie

Relazioni sociali non gerarchiche
(OpenPGP)

Percezione di bisogni differenti (la
firma serve per autenticare!)

Conflitto di interessi (Bisogni di
ripudiabilità/deniability o anonimato)

Percezione della sicurezza one-to-one
("la password di winzip è più
sicura!")

DPS/PEC -> Riservatezza?

Adeguamento alle misure minime:
implementazione di sistemi di AAA

Se i dati vengono “rubati”
sottraendo i media fisici o mediante
accesso logico questi vengono
violati poiché non cifrati

PEC: invio email con una
scocciatura in più

La basi dati e la confidenzialità

Le basi dati sono sempre sproteggiate

Basi dati di messaggi

Helpdesk/sistemisti/outsource/isp possono leggere le email?

Basi dati di valore

Autorizzazioni inutili se i dati non sono cifrati (credit card)

Sviluppatori, sistemisti, DBA, addetti ai backup possono accedervi?

Dischi cifrati

Quali informazioni proteggere?

Posta Elettronica

Documenti

Basi Dati

Archivi

Password

Dati in movimento

Registri di attività (log)

Da chi proteggere le informazioni?

Competitor

Outsourcer (Managed services)

Personale esterno (quanti consulenti!)

Personale interno infedele

- La segretaria

- Il collega

- Il gestore del sistema IT

Organizzazioni governative straniere

Organizzazioni governative nazionali

Rischi di mancata protezione

Perdita di competitività

Perdita di immagine

Fallimento strategie

Furto proprietà intellettuale

La vita

Opportunità di tutela

Il proliferare di strumenti di firma ci offre una base forte per la tutela della riservatezza:

Standard x509v3 con chiavi RSA

Hardware tamper proof (in teoria)

Facilità di scambio chiavi (S/MIME)

Indici centrali di verifica (bene o male, è una questione di contesto)

Disponibilità dei sistemi di firma

Oltre un milione di smartcard
emesse dai certificatori
accreditati

Carte di credito VISA

Carta nazionale dei servizi

Carta identità elettronica

PEC

SIM GSM (limitata)

Free S/MIME email certs

Modi d'uso

Autenticazione

Messaggistica email

Archiviazione documentale

Protezione infrastrutturale

Protezione delle connessioni
mobile

Modi d'uso: tecnologie

Email: S/MIME

HTTP SSL Client Auth

Wireless 802.11 EAP-TLS

Active Directory (SSO)

VPN IPSec

VPN SSL

(OpenVPN/Cisco/Nokia/Checkpoint/Fortinet, etc)

Riservatezza in ambienti complessi

Metodi crittografici articolati

Infrastrutture software crypto-aware

Condivisione dei dati

Escrow management (audit)

Protezione dell'identità

Trasparenza d'uso (exchange?)

Riassumendo

Gli ingredienti della riservatezza:

Standard accettato da tutti

Costo 0 per i supporti crittografici

Hardware tamper proof

Consapevolezza

Prospettive future

Sistemi federativi di autenticazione e autorizzazione

Sicurezza del sistema complessiva (tcpa)

Sicurezza delle comunicazioni voce

Sicurezza della messaggistica istantanea (i fw iniziano a farne inspection)

Riservatezza della riservatezza

Steganografia

Deniable double Encryption

Bibliografia

<http://www.privacyinternational.org>

<http://e-privacy.firenze.linux.it>

Feedback

L'impiego delle tecnologie di firma digitale per la tutela della confidenzialità

Domande?
Fabio Pietrosanti
naif@sikurezza.org

